Droit du numérique et protection des données

Informatique — Licence 3 (L3)

Cours INF-L3-19

Institut Africain de Management (IAM) — Bamako, Mali
Bibliothèque Universitaire — Bronbah Tech

À propos de ce cours

Connaître les règles du jeu numérique pour exercer son métier d'informaticien en toute sécurité juridique : protection des données personnelles (loi malienne de 2013, APDP, repères RGPD et Convention de Malabo), contrats informatiques, responsabilité des acteurs en ligne, cybercriminalité et valeur de la preuve électronique.

Document pédagogique original créé pour les étudiants de l'IAM : leçons détaillées, exemples commentés, travaux dirigés et pratiques, exercices corrigés, QCM d'évaluation et vidéos recommandées. Aucun contenu n'est reproduit d'ouvrages existants.

Sommaire

• Introduction à la matière
• Objectifs d'apprentissage
• Leçon 1 — Cadres juridiques du numérique : repères nationaux et internationaux
• Leçon 2 — Protection des données personnelles : principes et obligations
• Leçon 3 — Contrats informatiques : prestations de services et licences logicielles
• Leçon 4 — Responsabilité des hébergeurs et des éditeurs de contenus
• Leçon 5 — Cybercriminalité : principales infractions et sanctions
• Leçon 6 — Signature électronique et valeur de la preuve numérique
• Travaux dirigés (TD)
• Travaux pratiques (TP)
• Exercices corrigés supplémentaires
• QCM d'évaluation
• Résumé — les notions importantes
• Vidéos associées aux leçons
• Sources et références

Comment utiliser ce cours : lis chaque leçon dans l'ordre, refais les exemples à la main, tente chaque exercice AVANT de lire son corrigé, puis termine par le QCM pour vérifier ce que tu as retenu.

Introduction à la matière

Tu sais coder, configurer, déployer. Mais dès qu'une application touche à de vraies personnes — leurs noms, leurs numéros, leurs photos, leurs paiements — une autre discipline entre en jeu : le droit. Un informaticien qui ignore les règles sur les données personnelles, les contrats ou la cybercriminalité expose son employeur, ses clients et lui-même à des sanctions, à des litiges et à une perte de confiance parfois irréparable. Le droit du numérique n'est donc pas un luxe d'avocat : c'est une compétence professionnelle de l'informaticien moderne. Une fonctionnalité mal cadrée peut transformer un beau projet en problème juridique : données collectées « au cas où », composant logiciel utilisé sans licence, accès administrateur partagés sans aucune trace. À l'inverse, un informaticien qui connaît les règles pose les bonnes questions dès la conception, documente ses choix et gagne durablement la confiance de ses utilisateurs comme de sa hiérarchie.

Ce cours est une initiation, pas une formation de juriste. Son but est de te donner des repères solides : savoir quelles lois s'appliquent au Mali et dans l'espace régional, comprendre les principes que ces lois partagent presque partout dans le monde, et adopter les bons réflexes dans tes projets — documenter, minimiser, sécuriser, respecter les droits des personnes. Pour un cas précis et engageant, le réflexe final reste toujours le même : consulter un professionnel du droit. Tu n'apprendras donc pas à plaider, mais à repérer : reconnaître qu'une situation relève du droit des données, du droit des contrats ou du droit pénal, savoir quel texte consulter et quelle autorité saisir, et mesurer le moment où l'avis d'un juriste devient indispensable. Ces réflexes se travaillent comme ceux de la sécurité informatique : par la méthode, par des

exemples et par l'analyse d'erreurs réelles.

Avertissement de méthode, valable pour tout le cours : les lois évoluent, sont modifiées, complétées par des décrets et interprétées par les juges. Les références citées ici — loi malienne n° 2013-015 du 21 mai 2013 sur les données personnelles, RGPD européen, Convention de Malabo de l'Union africaine — sont des points de départ reconnus, mais avant d'agir en situation réelle, vérifie toujours la version en vigueur du texte et les positions de l'autorité compétente, au Mali l'APDP (Autorité de Protection des Données à caractère Personnel). Ce cours fait aussi un choix de prudence assumé : il ne cite aucun numéro d'article précis, aucun montant d'amende et aucune durée de peine que nous ne puissions garantir, car un chiffre faux serait plus dangereux qu'un repère général juste. Retiens les mécanismes et les principes ; les détails chiffrés se vérifient toujours dans le texte officiel du moment.

Objectifs d'apprentissage

À la fin de ce cours, tu seras capable de :

- Situer les principales sources du droit du numérique : loi malienne sur les données personnelles, textes régionaux et conventions internationales.
- Expliquer ce qu'est une donnée à caractère personnel et identifier un traitement de données dans un projet informatique.
- Appliquer les grands principes de protection des données : finalité, minimisation, sécurité, durées de conservation limitées.
- Énumérer les droits des personnes concernées et les obligations pratiques du responsable de traitement.
- Repérer les clauses essentielles d'un contrat informatique : périmètre, obligations, propriété intellectuelle, responsabilité, licences logicielles.
- Distinguer les régimes de responsabilité de l'hébergeur et de l'éditeur de contenus en ligne.
- Reconnaître les grandes familles d'infractions cybercriminelles et expliquer la valeur juridique de la signature électronique et des traces numériques.

Leçon 1 — Cadres juridiques du numérique : repères nationaux et internationaux

Le droit du numérique n'est pas une loi unique mais un empilement de textes. Au sommet des repères maliens, la Constitution garantit le respect de la vie privée, dont la protection des données personnelles est une déclinaison moderne. En dessous, des lois spécialisées organisent chaque domaine : la loi n° 2013-015 du 21 mai 2013 régit la protection des données à caractère personnel et crée l'autorité qui veille sur son application, l'APDP. Le Code pénal, lui, réprime les comportements les plus graves, et le droit des contrats encadre les relations entre les professionnels et leurs clients. On y ajoute le droit des obligations et les règles sectorielles, qui complètent le tableau selon l'activité : banque, santé, éducation ou télécommunications ont souvent leurs propres exigences, parfois plus strictes que le droit commun. Retenir cette architecture en couches — et savoir dans quelle couche chercher — est la première compétence que ce cours cherche à installer.

À ces textes nationaux s'ajoutent des couches régionales et internationales. L'Union africaine a adopté en 2014 la Convention de Malabo sur la cybersécurité et la protection des données à caractère personnel, qui invite les États africains à harmoniser leurs législations ; elle est entrée en vigueur en 2023. Le Règlement général sur la protection des données (RGPD) de l'Union européenne, applicable depuis 2018, joue un rôle de référence mondiale : dès qu'un service malien vise des clients situés en Europe, ou travaille avec des partenaires européens, ses exigences peuvent s'imposer en pratique, par exemple par le biais des contrats. D'autres références comptent aussi, comme la Convention de Budapest du Conseil de l'Europe consacrée à la cybercriminalité, qui sert de modèle à de nombreuses lois nationales dans le monde entier. Le point commun de tous ces textes : ils cherchent à protéger les personnes et la confiance dans les échanges numériques, et non à brider la technologie pour elle-même.

Comment s'y retrouver concrètement dans un projet ? Par une démarche en trois temps. D'abord, identifier les activités concernées : collecte-t-on des données personnelles ? vend-on un service en ligne ? stocke-t-on des contenus d'utilisateurs ? Ensuite, rattacher chaque activité à la règle qui la gouverne : loi données personnelles, droit des contrats, droit pénal, règles sectorielles (banque, santé, télécoms). Enfin, repérer l'autorité compétente en cas de question ou de contrôle : APDP pour les données, tribunaux pour les litiges, forces de sécurité et justice pénale pour les infractions. Cette carte mentale simple évite la plupart des erreurs de cadrage. Exemple rapide : une application de paiement des frais scolaires relève à la fois de la loi sur les données (fichiers d'élèves et de parents), du droit des contrats (conditions du service proposé aux familles) et, potentiellement, de la réglementation des paiements. Celui qui fait ce tri dès la réunion de cadrage évite de découvrir les contraintes la veille du lancement, quand elles coûtent dix fois plus cher à corriger.

L'essentiel
Le droit du numérique combine droit national (au Mali : loi n° 2013-015 de 2013 sur les données personnelles, Code pénal, droit des contrats), textes régionaux (Convention de Malabo de l'Union africaine) et références internationales influentes (RGPD européen). Dans un projet : identifier l'activité, la rattacher à la règle, repérer l'autorité compétente.

Exemple — Les couches de règles applicables à une boutique en ligne malienne

```
Projet : une PME de Bamako vend des tissus en ligne
et livre au Mali et en Europe.

COUCHE 1 — Droit malien (toujours applicable ici)
- Loi n° 2013-015 (21 mai 2013) : les fichiers
clients (noms, téléphones, adresses) sont des
traitements de données personnelles -> APDP.
- Droit des contrats et de la consommation :
prix affichés, conditions de vente, livraisons.
- Code pénal et loi sur la cybercriminalité :
en cas de fraude ou d'intrusion subie/commise.

COUCHE 2 — Droit régional africain
- Convention de Malabo (Union africaine) :
principes communs de protection des données
et de lutte contre la cybercriminalité.

COUCHE 3 — Références internationales
- RGPD européen : les clientes en Europe y sont
protégées ; les partenaires européens l'exigent
souvent dans leurs contrats.
- Convention de Budapest (Conseil de l'Europe) :
référence mondiale contre la cybercriminalité.

Reflexe : pour chaque fonctionnalité du site,
se demander « quelles données ? quelle règle ?
quelle autorité ? »
```

À retenir

- Au Mali, la protection des données personnelles repose sur la loi n° 2013-015 du 21 mai 2013, appliquée sous le contrôle de l'APDP.
- La Convention de Malabo (Union africaine, 2014) harmonise les principes en Afrique ; le RGPD européen sert de référence mondiale et peut s'appliquer via les clients ou les contrats.
- Méthode : identifier l'activité, la rattacher au texte applicable, repérer l'autorité compétente — avant de coder, pas après un incident.

Exercice

Une université privée de Bamako lance une application mobile de scolarité : les étudiants y consultent leurs notes, paient leurs frais par mobile money et reçoivent des notifications. Cite quatre familles de règles juridiques concernées par ce projet et, pour chacune, donne un exemple concret de question à se poser avant le lancement.

✔ Corrigé
1) Protection des données personnelles (loi de 2013, APDP) : les notes, identités et numéros de téléphone des étudiants sont des données personnelles — question : « avons-nous informé les étudiants et sécurisé ces données ? » 2) Droit des contrats : les conditions d'utilisation de l'application engagent l'université — question : « que promettons-nous exactement en cas de panne le jour des résultats ? » 3) Paiement électronique et droit bancaire/financier : les frais transitent par des opérateurs de mobile money — question : « qui est responsable si un paiement est débité deux fois ? » 4) Droit pénal et cybercriminalité : l'application peut être attaquée ou servir à frauder — question : « nos journaux (logs) permettront-ils de prouver ce qui s'est passé ? » Bonus : droit du travail si les enseignants saisissent les notes depuis leur téléphone personnel.

Leçon 2 — Protection des données personnelles : principes et obligations

Une donnée à caractère personnel est toute information qui permet d'identifier une personne, directement (nom, photo, numéro de téléphone) ou indirectement (identifiant de compte, adresse IP, combinaison d'informations). Un traitement est toute opération sur ces données : collecte, enregistrement, consultation, diffusion, effacement. La loi malienne de 2013 pose des principes que l'on retrouve dans la Convention de Malabo et dans le RGPD : traiter les données loyalement et pour des finalités déterminées et légitimes, ne collecter que le nécessaire (minimisation), garantir leur exactitude, les conserver pour une durée limitée, et surtout les sécuriser. Avant même de collecter la première donnée, il faut identifier ce qui rend le traitement licite : le consentement de la personne, l'exécution d'un contrat avec elle, une obligation légale, ou un autre fondement reconnu par la loi applicable. Ce fondement n'est pas un détail administratif : il conditionne l'information à donner, les droits ouverts et la manière dont les données pourront être utilisées ensuite.

Deux rôles structurent toutes les obligations. Le responsable du traitement décide des finalités et des moyens : c'est lui qui répond devant l'autorité et les personnes. Le sous-traitant agit pour son compte — hébergeur, prestataire de messagerie, société de maintenance — et doit offrir des garanties de sécurité suffisantes, formalisées dans un contrat. La personne concernée, elle, dispose de droits : être informée de l'usage de ses données, y accéder, les faire rectifier, s'opposer à certains usages et, selon les textes et les cas, obtenir leur effacement. Au Mali, l'APDP peut être saisie en cas de difficulté, et certains traitements doivent lui être déclarés ou autorisés selon leur nature. Concrètement, une autorité de ce type peut recevoir des plaintes, mener des contrôles et prononcer, selon la loi, des mesures allant du rappel à l'ordre à des sanctions. Anticiper son regard — traitements documentés, sécurité démontrée, réponses organisées aux demandes des personnes — est la meilleure manière de ne jamais la rencontrer en mauvaise posture.

Pour l'informaticien, ces principes deviennent des gestes techniques précis : chiffrer les mots de passe et les flux sensibles, gérer finement les droits d'accès (chacun ne voit que ce dont il a besoin), journaliser les consultations sensibles, prévoir l'export et

l'effacement des données d'un utilisateur, limiter la conservation des sauvegardes. L'outil central de pilotage est le registre des traitements : un tableau vivant qui décrit, pour chaque traitement, sa finalité, les données, les destinataires, les durées et les mesures de sécurité. Sans registre, impossible de prouver sa rigueur le jour d'un contrôle ou d'un incident. Un exercice simple révèle d'ailleurs l'état réel d'une organisation : demander à l'équipe de lister, en dix minutes, toutes les données personnelles que l'application manipule. Si la liste est incomplète ou si personne ne connaît les durées de conservation, le registre n'est pas un document de plus à produire — c'est le chantier prioritaire.

L'essentiel
Donnée personnelle = toute information identifiant une personne. Principes : finalité déterminée, minimisation, exactitude, conservation limitée, sécurité. Le responsable du traitement répond des choix ; le sous-traitant doit garantir la sécurité ; la personne a des droits (information, accès, rectification, opposition, effacement selon les cas). Outil clé : le registre des traitements.

Exemple — Extrait d'une politique de confidentialité modèle et droits des personnes

```
POLITIQUE DE CONFIDENTIALITE (extrait, modele
redige pour ce cours - a adapter avec un juriste)

Qui sommes-nous ? La cooperative « Djiguiya
Services », Bamako (Mali), est responsable du
traitement decrit ci-dessous.

Quelles donnees et pourquoi ?
- Nom, telephone : gerer votre commande et la
livraison (finalite : execution du contrat).
- Historique d'achats : etablir vos factures et
nos statistiques internes.

Combien de temps ? Les donnees de commande sont
conservees pendant la duree fixee par nos
obligations comptables, puis archivees ou
detruites. Aucune donnee n'est vendue a des tiers.

Vos droits (principes generaux) :
Droit d'acces ........ voir vos donnees
Droit de rectification corriger une erreur
Droit d'opposition .... refuser certains usages
(ex. prospection)
Droit a l'effacement .. demander la suppression
dans les cas prevus
Pour exercer ces droits : contact@exemple.ml en
justifiant de votre identite. En cas de desaccord,
vous pouvez saisir l'APDP (Mali).
```

À retenir

- Minimisation : si une donnée ne sert pas la finalité annoncée, on ne la collecte pas — un champ de formulaire doit toujours se justifier.
- La sécurité des données est une obligation juridique, pas seulement une bonne pratique technique : accès restreints, chiffrement, journaux, sauvegardes.
- Les droits des personnes (accès, rectification, opposition, effacement) doivent pouvoir s'exercer en pratique : prévois dès la conception les fonctions d'export et de suppression.

Exercice

Une application de livraison de repas demande à l'inscription : nom, téléphone, adresse, date de naissance, photo de la pièce d'identité et liste des contacts du téléphone « pour améliorer le service ». Analyse ce formulaire au regard des principes de la leçon : quelles données posent problème, et que proposerais-tu à la place ?

✔ Corrigé

Nom, téléphone et adresse sont nécessaires à la livraison : ils passent le test de minimisation, à condition d'être sécurisés et conservés pour une durée limitée. La date de naissance ne sert ni la commande ni la livraison : à supprimer, sauf justification précise (par exemple vérification d'âge pour certains produits, à expliquer alors clairement). La photo de la pièce d'identité est disproportionnée pour livrer un repas : risque majeur en cas de fuite, à retirer. La liste des contacts est le cas le plus grave : elle concerne des tiers qui n'ont rien demandé, et sa finalité (« améliorer le service ») est vague — double faute de finalité et de minimisation. Version corrigée du formulaire : nom, téléphone, adresse de livraison, mot de passe robuste, et une information claire sur les droits, avec un contact pour les exercer.

Leçon 3 — Contrats informatiques : prestations de services et licences logicielles

Un projet informatique sans contrat écrit est un litige en préparation. Le contrat de prestation de services fixe ce que le prestataire s'engage à livrer (périmètre fonctionnel, livrables, délais), ce que le client doit fournir (informations, validations, accès), le prix et les modalités de paiement, ainsi que les obligations de résultat ou de moyens qui s'appliquent : un éditeur qui s'engage sur un délai de correction ne promet pas la même chose qu'un consultant tenu à une obligation de moyens renforcée. Il précise aussi la recette — la procédure par laquelle le client vérifie et accepte les livrables — car c'est elle qui déclenche en général le paiement final et le départ des garanties. Le contrat prévoit aussi comment sont traités les désaccords sur les délais, car un retard en informatique vient rarement d'une seule partie : livrables validés tardivement, spécifications qui changent en cours de route, accès aux environnements fournis avec retard. Un bon contrat n'empêche pas les aléas, il dit à l'avance comment on les constate et comment on les partage.

Trois blocs de clauses protègent particulièrement l'informaticien comme le client. La propriété intellectuelle : qui détient les droits sur le code développé ? À défaut de clause claire, les malentendus sont fréquents — le client paie-t-il un droit d'usage ou la pleine propriété des développements spécifiques ? La responsabilité et ses limites :

que se passe-t-il si le logiciel fait perdre des données ou bloque l'activité du client, et les dommages couverts sont-ils plafonnés ? Enfin, la maintenance et les niveaux de service (délais d'intervention, de rétablissement, disponibilité visée), qui transforment des promesses vagues (« on intervient vite ») en engagements mesurables. Signalons enfin la clause de confidentialité, qui survit souvent à la fin du contrat, et celle de réversibilité : à la sortie, le client doit pouvoir récupérer ses données dans un format exploitable et faire travailler un autre prestataire. Le jour de la rupture, on ne négocie plus rien dans de bonnes conditions : tout se joue dans ce qui a été écrit au départ.

Les licences logicielles sont l'autre grand contrat du quotidien numérique. Acheter un logiciel, c'est presque toujours acquérir un droit d'usage limité par une licence, et non le logiciel lui-même. Les licences propriétaires restreignent l'installation, la copie ou le nombre d'utilisateurs ; les licences libres (par exemple les licences de type GPL, MIT ou Apache, dont il faut lire les conditions exactes) autorisent largement l'usage, la modification et la redistribution, parfois sous conditions, comme le partage des modifications. Utiliser un composant sans vérifier sa licence expose à des poursuites pour contrefaçon — un risque réel pour un produit commercial, même si le composant est gratuit. Le même réflexe vaut pour les contenus : polices de caractères, photographies, icônes et extraits de code publiés en ligne ont chacun leurs ayants droit et leurs conditions. Tenir un inventaire des composants et de leurs licences, mis à jour à chaque version, est une tâche modeste en développement et inestimable le jour d'un audit, d'un contrôle ou d'une recherche de financement.

L'essentiel
Le contrat de prestation définit périmètre, livrables, prix, recette, propriété intellectuelle, responsabilités et niveaux de service. Une licence logicielle concède un droit d'usage, pas la propriété du programme : propriétaires restrictives ou libres aux conditions à respecter, utiliser un logiciel sans licence valide constitue une contrefaçon potentielle.

Exemple — Les clauses essentielles d'un contrat de prestation informatique (décrites)

```
CONTRAT DE PRESTATION — LES CLAUSES A PRESENTER
(grille de lecture originale, pas un modele a
recopier : chaque contrat se redige sur mesure)

1. Objet et perimetre : ce qui est livre, et
explicitement ce qui ne l'est pas.
2. Livrables et recette : liste des livrables,
delai laisse au client pour tester, effets
de l'acceptation (ou du silence prolonge).
3. Prix et paiement : montant, echeancier,
penalites de retard eventuelles.
4. Delais : calendrier, dependances (ce que le
client doit fournir et quand), gestion des
retards des deux cotes.
5. Propriete intellectuelle : droits sur les
developpements specifiques, sur les outils
preexistants du prestataire, licences des
composants tiers utilises.
6. Confidentialite et donnees personnelles :
secret professionnel, roles de responsable
et de sous-traitant, mesures de securite.
7. Responsabilite : dommages couverts,
plafonds eventuels, exclusions.
8. Maintenance et niveaux de service : delais
d'intervention et de retablissement vises.
9. Fin du contrat : reversibilite (recuperation
des donnees et des codes), assistance de
sortie, sort des acces administrateur.
```

À retenir

- La recette est le moment juridique clé d'un projet : elle constate l'acceptation des livrables et conditionne paiement et garanties.
- Toujours trancher par écrit la propriété intellectuelle des développements et le statut des composants tiers (et leurs licences).
- « Gratuit » ne veut pas dire « sans licence » : chaque logiciel libre a des conditions (attribution, partage des modifications…) qu'il faut lire et respecter.

Exercice

Une association te commande un site web « clé en main » par échange de messages, sans contrat. Le site est livré et payé. Six mois plus tard, l'association découvre qu'elle ne peut pas faire modifier le site par un autre prestataire : le développeur affirme que le code lui appartient et refuse de transmettre les accès. Explique quels risques cette situation illustre et cite quatre points qu'un contrat écrit minimal aurait dû fixer dès le départ.

✔ Corrigé
L'absence d'écrit rend tout incertain : étendue des droits cédés sur le code, propriété du nom de domaine, transmission des accès, possibilités de maintenance par un tiers. En pratique, les droits d'auteur sur un logiciel appartiennent en principe à leur auteur ou à son employeur selon les situations prévues par la loi et le contrat ; le client qui a « payé un site » n'a souvent acquis qu'un droit d'usage, d'où le blocage. Un contrat minimal aurait fixé : 1) la propriété ou la licence du code développé et les droits de modification ; 2) la propriété du nom de domaine et des comptes (hébergement, réseaux sociaux) au nom du client ; 3) la remise des livrables techniques : codes sources, documentation, accès administrateur ; 4) la maintenance et la réversibilité : conditions d'intervention future et assistance en cas de changement de prestataire. Leçon générale : le contrat n'est pas de la méfiance, c'est la mémoire écrite du projet.

Leçon 4 — Responsabilité des hébergeurs et des éditeurs de contenus

Sur un site ou une plateforme, qui répond d'un commentaire diffamatoire, d'une annonce frauduleuse ou d'une image volée ? Le droit distingue deux grandes figures. L'éditeur de contenus choisit, rédige ou valide ce qui est publié : il répond de ces contenus comme de ses propres paroles, avec les responsabilités civile et parfois pénale qui s'y attachent. L'hébergeur, au contraire, stocke techniquement des contenus fournis par des tiers — utilisateurs, annonceurs, membres — sans les choisir : exiger de lui qu'il surveille tout, en permanence, serait à la fois impossible et dangereux pour la liberté d'expression. La distinction repose donc sur le degré de contrôle exercé : l'éditeur opère un choix éditorial, l'hébergeur fournit un service technique de stockage et d'accès. Entre les deux, beaucoup de plateformes sont hybrides : un réseau social héberge les vidéos de ses membres, mais il en recommande certaines par ses propres choix de mise en avant — ce qui peut rapprocher son rôle, pour ces contenus, de celui d'un éditeur.

Les législations modernes — la loi française pour la confiance dans l'économie numérique (LCEN, 2004) est la référence la plus souvent citée dans l'espace francophone, et de nombreux pays s'en inspirent ou adoptent des logiques voisines — accordent donc à l'hébergeur un régime de responsabilité allégé et conditionnel : il n'est en principe pas responsable des contenus qu'il stocke tant qu'il n'a pas connaissance de leur caractère manifestement illicite ; en revanche, dès qu'un contenu illégal lui est valablement signalé, il doit agir promptement pour le retirer ou en bloquer l'accès, sous peine d'engager sa responsabilité. C'est le mécanisme dit de « notification et retrait ». Cet équilibre mérite d'être compris : il protège l'innovation et la liberté d'expression — sans lui, aucune plateforme ne prendrait le risque d'héberger les contenus de millions d'inconnus — tout en offrant aux victimes une voie d'action rapide, sans devoir d'abord passer devant un juge. La contrepartie exigée de l'hébergeur est la diligence : des moyens de signalement réels, des délais de traitement sérieux et une conservation des éléments qui permettront ensuite, si besoin, à la justice de travailler.

Pour un futur professionnel, les conséquences sont très concrètes. D'abord, déterminer son statut : un blog d'entreprise est éditeur de ses articles mais hébergeur des commentaires de ses lecteurs ; une place de marché héberge les annonces de ses vendeurs mais édite ses propres pages. Ensuite, organiser la modération : formulaire de signalement accessible, procédure écrite de traitement des notifications, journal des décisions, délais réalistes. Enfin, ne jamais oublier les obligations qui subsistent : conservation de certaines données de connexion pour les besoins de la justice selon la loi applicable, coopération avec les autorités sur réquisition, et protection des données des utilisateurs signalants comme signalés. Dernier point de vigilance : le rôle de simple hébergeur se perd lorsqu'on intervient activement sur les contenus — sélection, réécriture, présentation comme siens. Une plateforme qui réécrit les annonces de ses vendeurs ou qui certifie leur contenu sans réserve se rapproche du statut d'éditeur pour ces contenus, avec les responsabilités correspondantes. La ligne se trace donc dans les pratiques réelles, et pas dans l'étiquette que l'entreprise se donne elle-même.

L'essentiel
L'éditeur répond des contenus qu'il choisit ou valide. L'hébergeur, qui stocke des contenus de tiers, bénéficie d'un régime allégé : pas de surveillance générale exigée, mais obligation d'agir promptement lorsqu'un contenu manifestement illicite lui est signalé (notification et retrait). Dans le doute sur les textes exacts applicables, on vérifie la loi en vigueur dans le pays concerné.

Exemple — Procédure de notification et retrait sur une plateforme d'annonces

```
NOTIFICATION ET RETRAIT — DEROULEMENT TYPE
(procedure interne simplifiee, a adapter a la
legislation du pays d'etablissement)

ETAPE 1 — Signalement
Un utilisateur signale une annonce via le
formulaire prevu : description du contenu,
adresse (URL), motif invoque (contrefacon,
escroquerie supposee, propos illegaux...).

ETAPE 2 — Accuse de reception et examen
La plateforme accuse reception, horodate le
dossier et verifie : contenu reellement en
ligne ? caractere manifestement illicite ?

ETAPE 3 — Decision proportionnee
- Contenu manifestement illicite : retrait
rapide ou blocage de l'acces.
- Cas douteux : demande de precisions,
eventuellement avis juridique, decision
motivee et tracee.

ETAPE 4 — Information et archives
L'auteur de l'annonce est informe de la
mesure et des voies de contestation.
Le dossier (signalement, preuves, decision)
est conserve : il prouve la diligence de
l'hebergeur si sa responsabilite est mise
en cause.

A RETENIR : ni retrait automatique de tout ce
qui est signale, ni inaction — une procedure
rapide, documentee et proportionnee.
```

À retenir

- Le même acteur peut être éditeur pour ses propres contenus et hébergeur pour ceux de ses utilisateurs : le régime de responsabilité suit le contenu, pas l'entreprise.
- Le cœur du régime de l'hébergeur : pas d'obligation générale de surveillance, mais une réactivité obligatoire après signalement d'un contenu manifestement illicite.
- Une procédure de modération écrite, un formulaire de signalement visible et un journal des décisions sont des protections juridiques autant que des outils de confiance.

Exercice

Un forum malien de passionnés d'informatique reçoit le signalement suivant : un membre affirme qu'un autre membre a copié son tutoriel et le vend sur le forum sans autorisation. Le contenu copié n'est pas « manifestement » illicite aux yeux d'un non-juriste : la paternité est contestée par l'autre membre. Que doit faire l'hébergeur du forum, étape par étape, pour rester dans une position juridiquement prudente ?

✔ Corrigé
1) Accuser réception du signalement et ouvrir un dossier horodaté, avec les éléments fournis (tutoriel d'origine, dates, preuves d'antériorité éventuelles). 2) Ne pas trancher le litige d'auteur soi-même : l'hébergeur n'est pas un juge ; en revanche, le caractère illicite n'étant pas manifeste, il peut demander des précisions aux deux parties. 3) Prendre une mesure proportionnée et réversible si le risque est sérieux : par exemple masquer temporairement la vente litigieuse le temps de l'examen, en informant les deux membres. 4) Inviter le membre s'estimant lésé à saisir les voies compétentes (médiation, autorité compétente en matière de droit d'auteur, tribunal) et lui expliquer que le contenu pourra être retiré sur décision ou accord clair. 5) Tracer toutes les décisions dans le journal de modération. L'erreur à éviter aux deux extrêmes : tout supprimer sans examen (risque de censure abusive et de conflit avec l'autre membre) ou ne rien faire du tout (risque d'être accusé d'inaction face à une contrefaçon avérée).

Leçon 5 — Cybercriminalité : principales infractions et sanctions

La cybercriminalité regroupe les infractions commises au moyen d'un système informatique ou contre celui-ci. Première famille : les atteintes aux systèmes eux-mêmes — accéder ou se maintenir frauduleusement dans un système, entraver son fonctionnement, introduire, modifier ou supprimer frauduleusement des données. Point essentiel pour des étudiants en informatique : la simple curiosité ne protège pas. Tester la sécurité du système de son école ou d'une entreprise sans autorisation écrite, même « pour vérifier » et sans rien voler, peut déjà constituer une infraction. Le droit distingue l'attaquant du professionnel mandaté : c'est l'autorisation préalable qui fait toute la différence. Ajoutons l'entrave aux systèmes : saturer volontairement un service pour le rendre inaccessible, même quelques heures, entre dans cette catégorie d'atteintes. L'interception de données ou de communications en transit par une personne non autorisée — y compris un salarié curieux sur le réseau de sa propre entreprise — relève elle aussi du droit pénal dans de nombreux pays.

Deuxième famille : les infractions commises grâce à l'outil informatique, souvent plus anciennes que le numérique mais démultipliées par lui. L'escroquerie en ligne (faux vendeur, faux support technique, promesses d'argent facile), l'usurpation d'identité, le chantage à partir de données volées ou d'images intimes, le harcèlement en ligne et la diffusion de contenus illicites en sont des exemples. Troisième famille : les atteintes aux données et aux biens immatériels — vol ou recel de fichiers, contrefaçon de logiciels et d'œuvres, espionnage économique. Dans la plupart des législations, ces comportements exposent à des sanctions pénales pouvant aller, selon la gravité, de l'amende à des peines d'emprisonnement prévues par la loi, auxquelles s'ajoutent la réparation des dommages causés aux victimes. Point de vigilance pour de futurs professionnels : certaines victimes deviennent auteures malgré elles — relayer un fichier volé, acheter des identifiants proposés « à bas prix », réutiliser des données dérobées dans un devoir ou un projet. Le recel et l'utilisation de données d'origine illicite sont en effet punissables, au même titre que les actes qui ont permis de les obtenir.

Le Mali, comme de nombreux États africains, a complété son droit pénal par un dispositif spécifique de répression de la cybercriminalité, et la Convention de Malabo comme la Convention de Budapest organisent la coopération internationale, indispensable car les attaques ignorent les frontières. Pour la victime — entreprise, administration ou particulier — les bons réflexes conditionnent toute la suite : préserver les preuves (ne pas effacer les journaux, conserver les messages et captures), porter plainte auprès des services compétents, et signaler l'incident à son autorité de protection des données lorsque des données personnelles sont touchées. Pour l'informaticien, enfin, une ligne rouge absolue : ne jamais « contre-attaquer » soi-même ; la riposte technique hors cadre légal devient une infraction, même contre son agresseur.

L'essentiel
Trois familles d'infractions : atteintes aux systèmes (accès et maintien frauduleux, entrave, altération de données — même sans vol et même « pour tester » sans autorisation), infractions facilitées par l'informatique (escroquerie, usurpation d'identité, chantage, harcèlement), atteintes aux données et aux œuvres (vol de fichiers, contrefaçon). Sanctions pénales prévues par la loi (amendes et emprisonnement selon la gravité) plus réparation civile des victimes.

Exemple — Grandes familles d'infractions : repérer sans mode opératoire

```
FAMILLES D'INFRACTIONS (categories juridiques,
delibérément sans aucun detail technique)

1. ATTEINTES AUX SYSTEMES
- Acces frauduleux a un systeme informatique
- Maintien frauduleux apres un acces
- Entrave au fonctionnement d'un systeme
- Introduction, modification ou suppression
frauduleuse de donnees
-> Le critere cle : l'ABSENCE D'AUTORISATION
du proprietaire du systeme.

2. INFRACTIONS FACILITEES PAR L'INFORMATIQUE
- Escroquerie en ligne (faux vendeur, faux
investissement, faux support technique)
- Usurpation d'identite numerique
- Chantage et extorsion a partir de donnees
ou d'images obtenues illicitement
- Harcelement et menaces en ligne
- Diffusion de contenus illegaux

3. ATTEINTES AUX DONNEES ET AUX OEUVRES
- Vol, detournement ou recel de fichiers
- Contrefacon de logiciels et d'oeuvres
protegees (copie et diffusion illegales)
- Atteintes aux secrets d'affaires

Dans les trois familles : sanctions penales
prevues par la loi applicable, et indemnisation
des victimes a ajouter. Verifier toujours le
texte en vigueur (il evolue regulierement).
```

À retenir

- L'autorisation préalable du propriétaire du système est la frontière entre le test de sécurité légal et l'infraction : toujours écrite, toujours avant.
- L'escroquerie et l'usurpation d'identité sont des infractions « classiques » aggravées par l'échelle et l'anonymat relatifs d'Internet.
- Victime ? Préserver les preuves, porter plainte, signaler si des données personnelles sont concernées — et ne jamais riposter techniquement soi-même.

Exercice

Trois situations : a) Un étudiant découvre que le mot de passe de l'administration du réseau de son institut est faible ; sans rien demander, il se connecte « pour vérifier », regarde deux écrans et se déconnecte sans rien modifier. b) Une prestataire est mandatée par écrit par une PME pour tester la sécurité de son site pendant une semaine. c) Un internaute crée un faux profil au nom d'une commerçante connue et encaisse des commandes jamais livrées. Pour chaque cas, dis si une infraction est constituée (ou probable), en justifiant par la notion clé de la leçon.

✔ Corrigé
a) Infraction probable : l'accès et le maintien dans un système sans autorisation sont punissables en eux-mêmes dans la plupart des législations sur la cybercriminalité ; l'absence de vol ou de modification n'efface pas l'infraction, et la bonne intention ne remplace pas l'autorisation. Le bon réflexe était de signaler la faiblesse à l'administration. b) Aucune infraction : le mandat écrit de la propriétaire du système, avec un périmètre et une durée définis, est précisément ce qui rend le test légal — c'est le métier de l'audit de sécurité encadré. c) Plusieurs infractions probables : usurpation d'identité et escroquerie (commandes encaissées sans livraison), avec sanctions pénales possibles et obligation de réparer le préjudice des clientes trompées et de la commerçante usurpée. Les trois cas montrent que le droit juge d'abord l'autorisation et la tromperie, pas la prouesse technique.

Leçon 6 — Signature électronique et valeur de la preuve numérique

Un contrat peut-il naître d'un échange de courriels ? Un document PDF signé « à l'écran » vaut-il un papier signé à la main ? Les droits modernes répondent en substance : l'écrit électronique peut avoir la même valeur que l'écrit papier, à condition de garantir deux choses — l'identification fiable de son auteur et l'intégrité de son contenu, c'est-à-dire la certitude qu'il n'a pas été modifié depuis sa création. C'est le principe d'équivalence fonctionnelle : le droit ne protège pas le papier en tant que tel, mais les garanties que le papier apportait (qui a signé ? le texte est-il intact ?). Cette logique explique pourquoi le droit s'intéresse peu au support : un message électronique, un enregistrement de transaction ou un fichier journal peuvent valoir écrit, dès lors que leur origine et leur conservation sont fiables. Ce qui est écarté ou sanctionné, ce n'est pas le numérique en soi — c'est l'incertitude sur la provenance.

La signature électronique est le procédé technique et juridique qui apporte ces garanties. Il ne faut pas la confondre avec une image de signature collée dans un document, qui ne prouve presque rien. Une signature électronique au sens juridique repose sur un procédé d'identification du signataire lié au document signé : toute modification ultérieure du document devient détectable. Les cadres de référence — le règlement européen eIDAS est le plus connu, et plusieurs États africains ont adopté ou préparent leurs propres textes sur les transactions électroniques — distinguent en général des niveaux de garantie croissants, la signature dite « qualifiée », adossée à un certificat délivré par un prestataire contrôlé, bénéficiant de la présomption la plus forte. Retiens la gradation pratique qui en découle : plus l'enjeu du document est élevé — acte de vente, engagement financier important, document officiel — plus le niveau de garantie du procédé de signature doit être fort, et plus il faut soigner les preuves qui l'entourent.

La preuve numérique déborde largement la signature : journaux de connexion, courriels, captures d'écran, enregistrements de vidéosurveillance, historiques de paiement mobile sont autant d'éléments qu'un juge peut examiner. Leur force dépend de leur fiabilité : une capture d'écran se fabrique facilement, tandis qu'un journal horodaté, conservé dans des conditions garantissant son intégrité (par exemple avec

empreinte cryptographique et accès contrôlés), pèse beaucoup plus lourd. Deux réflexes d'informaticien en découlent : concevoir les systèmes pour produire des traces fiables et datées, et conserver ces traces dans le respect du droit — durées limitées, finalités connues, car une preuve collectée illicitement peut être écartée et même engager la responsabilité de son auteur. Les informaticiens rencontrent d'ailleurs cette question dans les deux sens : concevoir des traces solides lorsque le système est victime, et respecter les droits lorsqu'il surveille — journaliser l'activité des salariés, par exemple, constitue un traitement de données personnelles qui doit rester proportionné et porté à leur connaissance.

L'essentiel
L'écrit électronique vaut l'écrit papier si l'auteur est identifiable et l'intégrité garantie. La signature électronique est un procédé d'identification lié au document, sans rapport avec une image de signature ; les niveaux qualifiés offrent la présomption la plus forte. La valeur d'une preuve numérique dépend de sa fiabilité et de la licéité de sa collecte.

Exemple — Anatomie d'une signature électronique fiable, étape par étape

```
SIGNER ELECTRONIQUEMENT UN DOCUMENT — LE PRINCIPE
(description pedagogique simplifiee)

1. IDENTIFICATION du signataire
Un prestataire verifie l'identite de la
personne (piece d'identite, controles) et
lui delivre un certificat electronique.

2. EMPREINTE du document
Le logiciel calcule une empreinte unique
du document (fonction de hachage) : la
moindre modification change l'empreinte.

3. SCELLEMENT
L'empreinte est chiffree avec la cle privee
du signataire : c'est la signature, liee a
la fois a la personne et a CE document.

4. HORODATAGE (recommande)
Une autorite d'horodatage atteste la date
et l'heure de la signature.

5. VERIFICATION par le destinataire
Avec le certificat (cle publique), il
controle : signature valide, document non
modifie, certificat non expire/revoque.

Ce que cela prouve : qui a signe, que le
texte est intact, quand. Ce que cela ne
prouve pas : que le contenu dit vrai — la
signature garantit l'origine et l'integrite,
pas l'exactitude des affirmations signees.
```

À retenir

- Équivalence fonctionnelle : l'écrit électronique est admis comme l'écrit papier si l'auteur est identifiable et l'intégrité du contenu garantie.
- Une image de signature dans un PDF n'est pas une signature électronique : celle-ci lie cryptographiquement le signataire au document et rend toute modification détectable.
- En cas de litige, la qualité des traces (horodatage, journaux intègres, conservation maîtrisée) décide souvent de la force de la preuve numérique.

Exercice

Une PME reçoit d'un fournisseur un « contrat signé » : un PDF où figure l'image scannée d'une signature manuscrite. Trois semaines plus tard, le fournisseur conteste le prix indiqué dans le PDF et affirme n'avoir signé qu'une version différente. Explique pourquoi la PME est en position fragile, puis propose trois mesures techniques et organisationnelles qui auraient sécurisé la preuve de cet accord.

✔ Corrigé
Fragilité : l'image d'une signature peut être copiée d'un document à l'autre et le PDF modifié sans trace visible ; la PME peine à prouver à la fois l'identité du signataire et l'intégrité du texte — c'est exactement les deux garanties que le droit exige. Mesures : 1) Utiliser un procédé de signature électronique avec certificat identifiant le signataire et scellant le document, idéalement horodaté par un tiers. 2) Conserver l'original signé et ses preuves (accusés, journaux de la plateforme de signature, courriels d'accompagnement) dans un espace d'archivage à accès contrôlé, en empêchant toute modification silencieuse (empreintes de contrôle). 3) Contractualiser la méthode : une clause du contrat-cadre peut prévoir le procédé de signature admis entre les parties et la conservation des preuves, ce qui évite la contestation du procédé lui-même. Complément : confirmer par courriel séparé les points essentiels (prix, délais) crée une trace concordante supplémentaire.

Travaux dirigés (TD)

TD 1 — Construire le registre des traitements d'une petite clinique

Une clinique privée de Bamako utilise un logiciel de dossiers patients, un registre papier des rendez-vous, une messagerie pour envoyer les résultats d'analyses et une page sur un réseau social. Construis son registre des traitements simplifié : pour chaque traitement, indique la finalité, les catégories de données, les personnes concernées, les destinataires, la durée de conservation proposée et deux mesures de sécurité adaptées. Signale le traitement qui exige la plus grande vigilance et explique pourquoi.

✔ Corrigé du TD 1
Registre simplifié — Traitement 1 « Dossiers patients » : finalité = suivi médical ; données = identité, antécédents, résultats (données de santé, particulièrement sensibles) ; personnes = patients ; destinataires = personnel soignant habilité ; conservation = durée nécessaire au suivi puis archivage selon les règles sanitaires applicables ; sécurité = comptes nominatifs avec mots de passe robustes, postes verrouillés, accès limité aux soignants. Traitement 2 « Rendez-vous » : finalité = organisation des consultations ; données = nom, téléphone, motif général ; conservation = durée courte après le rendez-vous ; sécurité = registre papier rangé sous clé, accès au seul secrétariat. Traitement 3 « Envoi des résultats par messagerie » : finalité = transmission au patient ; sécurité = vérification du numéro avant envoi, envoi du résultat en pièce jointe protégée plutôt que dans le corps du message. Traitement 4 « Page publique » : finalité = information ; aucune donnée de patient ne doit jamais y figurer. Vigilance maximale : le traitement 1 (et son prolongement 3), car les données de santé comptent parmi les plus sensibles — leur divulgation cause un préjudice grave aux personnes ; la messagerie grand public est le maillon faible à encadrer en priorité.

TD 2 — Qualifier juridiquement trois situations de terrain

Pour chaque situation, indique le domaine du droit principalement concerné et le réflexe correct : a) Une entreprise reçoit la demande d'un ancien client qui exige la suppression de toutes ses données « parce que c'est mon droit ». b) Un développeur réutilise dans un produit payant un composant trouvé sur Internet, sans avoir lu sa licence. c) Le gérant d'une plateforme découvre, signalée par plusieurs utilisateurs, une annonce vendant des documents d'identité volés.

✔ Corrigé du TD 2
a) Protection des données personnelles : les droits des personnes incluent, dans les cas prévus par la loi applicable, la possibilité de demander l'effacement ; mais certaines données doivent légalement être conservées (factures, obligations comptables). Réflexe : répondre dans un délai raisonnable, effacer ce qui peut l'être, expliquer par écrit ce qui doit être conservé et pourquoi, tracer la demande et la réponse. b) Propriété intellectuelle et contrats (licences) : « trouvé sur Internet » ne signifie pas libre de droits ; selon la licence du composant, l'usage commercial peut être interdit ou conditionné (attribution, partage des modifications). Réflexe : identifier la licence exacte avant tout usage, la consigner dans un inventaire des composants, et remplacer le composant si ses conditions sont incompatibles avec le produit. c) Responsabilité de l'hébergeur et droit pénal : des documents d'identité volés sont un contenu manifestement illicite, potentiellement lié à des infractions (vol, usurpation). Réflexe : retrait prompt de l'annonce, conservation du dossier et des preuves (ne pas tout effacer), information des autorités si la procédure interne ou la loi le prévoit, et réponse documentée aux utilisateurs signalants.

Travaux pratiques (TP)

TP 1 — Audit juridique simplifié d'une application de ton choix

Choisis une application réelle que tu as développée ou étudiée cette année (site de stage, projet de classe, application personnelle). Produis un mini-audit juridique en cinq livrables : 1) l'inventaire des données personnelles traitées et leur finalité ; 2) les droits des personnes : l'application permet-elle concrètement l'accès, la rectification et la suppression ? ; 3) l'inventaire des logiciels et composants tiers avec leur licence ; 4) les contrats ou leur absence (conditions d'utilisation, hébergeur, clients) ; 5) un plan de mise en conformité en cinq actions classées par priorité, avec pour chacune le risque qu'elle réduit.

✔ Attendus du TP 1

Attendus (exemple de démarche aboutie) : 1) Inventaire honnête et complet — par exemple pour une application de gestion d'école : comptes élèves, notes, paiements, journaux de connexion ; chaque ligne du tableau indique finalité et durée de conservation, et fait apparaître au moins une donnée collectée « au cas où » à supprimer (minimisation). 2) Constat réaliste : accès et rectification possibles via le secrétariat mais pas en autonomie ; suppression non prévue dans le code → action prioritaire n° 1 : ajouter une procédure d'export et d'effacement documentée. 3) Inventaire des composants : cadre de développement, bibliothèques JavaScript, police de caractères, images — avec la licence de chacun et un drapeau sur tout élément de licence inconnue. 4) Contrats : conditions d'utilisation absentes → action : rédiger une page claire (données traitées, droits, contact), et vérifier le contrat d'hébergement (localisation des données, sauvegardes). 5) Plan priorisé type : sécuriser les accès administrateurs (risque d'intrusion), ajouter l'effacement (risque de non-respect des droits), rédiger les conditions d'utilisation (risque de litige), vérifier les licences (risque de contrefaçon), mettre en place le registre (risque de contrôle sans preuve de diligence). Le TP est réussi si le plan est concret, chiffré en effort, et si chaque action est reliée à un risque nommé.

Exercices corrigés supplémentaires

Exercice 1

Vrai ou faux, en justifiant chaque réponse en une phrase : 1) « Si une application est gratuite pour les utilisateurs, elle n'a aucune obligation sur leurs données. » 2) « Un hébergeur doit lire et valider chaque contenu avant sa mise en ligne. » 3) « Signer un document avec une signature électronique qualifiée peut engager autant qu'une signature manuscrite. » 4) « Copier un logiciel libre est toujours interdit. »

✔ Corrigé
1) Faux : les obligations de protection des données naissent du traitement de données personnelles, pas du prix du service ; un service gratuit traite souvent même davantage de données (publicité, statistiques). 2) Faux : le régime de l'hébergeur repose au contraire sur l'absence d'obligation générale de surveillance préalable ; son devoir est de réagir promptement aux signalements de contenus manifestement illicites. 3) Vrai : les dispositifs de signature qualifiée bénéficient de la présomption la plus forte d'équivalence avec la signature manuscrite, grâce à l'identification vérifiée et à l'intégrité garantie. 4) Faux : les logiciels libres autorisent la copie, l'usage et souvent la modification et la redistribution ; ce sont leurs licences qui en fixent les conditions (par exemple attribution ou partage des modifications), et c'est le non-respect de ces conditions qui devient illicite.

Exercice 2

Une start-up veut lancer au Mali un service de mise en relation entre patients et pharmacies, avec géolocalisation des utilisateurs et envoi d'ordonnances photographiées. Liste cinq obligations ou précautions juridiques à traiter AVANT le lancement, en expliquant le risque visé par chacune.

✔ Corrigé
1) Données de santé et données sensibles : les ordonnances photographiées sont des données de santé — mesures de sécurité renforcées, accès strictement limités, information claire des patients ; risque visé : atteinte grave à la vie privée en cas de fuite. 2) Géolocalisation : donnée personnelle intrusive — la limiter au moment de la recherche, ne pas conserver l'historique des positions sans nécessité, informer et permettre la désactivation ; risque : suivi permanent des personnes. 3) Déclarations auprès de l'APDP et conformité à la loi malienne de 2013 pour des traitements de cette sensibilité ; risque : exercice sans cadre légal d'un traitement à risque. 4) Contrats avec les pharmacies et les sous-traitants techniques (hébergeur, envoi de notifications) : responsabilités, sécurité, sort des données en fin de contrat ; risque : chaîne de responsabilité floue en cas d'incident. 5) Exactitude et responsabilité de l'information : le service ne doit pas se substituer à l'avis du pharmacien ou du médecin ; prévoir la modération des contenus et la procédure de signalement ; risque : dommage sanitaire et mise en cause de la plateforme. Bonus : vérifier les règles sectorielles de la santé et de la pharmacie, qui s'ajoutent au droit commun du numérique.

Exercice 3

Après une intrusion dans son serveur, une entreprise retrouve ses journaux de connexion partiellement effacés par l'attaquant. Son directeur veut « reconstituer » les journaux manquants à partir de ses souvenirs pour les donner à la police. Explique pourquoi c'est une mauvaise idée, puis propose quatre mesures qui auraient rendu les traces exploitables comme preuves.

✔ Corrigé
Pourquoi c'est une mauvaise idée : un journal « reconstitué » n'est plus une preuve mais un récit ; s'il est présenté comme authentique, il peut être contesté par la défense, discréditer l'ensemble du dossier et, dans le pire des cas, exposer son auteur à des accusations de faux. La valeur d'une preuve tient à son intégrité vérifiable, pas à sa complétude. Quatre mesures préventives : 1) Externaliser les journaux en temps réel vers un serveur distinct, auquel les attaquants du premier serveur n'ont pas accès. 2) Protéger les journaux en écriture seule ou en lecture seule pour les administrateurs courants, avec des comptes d'administration séparés. 3) Horodater de façon fiable (synchronisation des horloges, source de temps commune) pour pouvoir relier les événements entre machines. 4) sceller périodiquement les journaux par empreinte cryptographique et tester la procédure de conservation et d'extraction des preuves, afin de démontrer, le jour venu, que les fichiers présentés sont bien ceux d'origine.

QCM d'évaluation

Choisis la bonne réponse pour chaque question. Les corrigés détaillés se trouvent juste après le QCM : ne les regarde qu'après avoir répondu à tout.

1. Au Mali, la protection des données à caractère personnel repose principalement sur…

A) La loi n° 2013-015 du 21 mai 2013

B) Un simple usage professionnel

C) Le seul RGPD européen

2. Laquelle de ces informations est une donnée à caractère personnel ?

A) Le chiffre d'affaires d'une société

B) Le numéro de téléphone d'un client

C) La météo de Bamako

3. Le principe de minimisation signifie…

A) Chiffrer toutes les données

B) Ne conserver les données qu'un jour

C) Ne collecter que les données nécessaires à la finalité annoncée

4. Qui décide des finalités et des moyens d'un traitement et en répond devant l'autorité ?

A) Le sous-traitant

B) Le responsable du traitement

C) L'utilisateur final

5. Lequel de ces droits n'est pas un droit classique des personnes concernées ?

A) Le droit d'accès à ses données

B) Le droit de rectification

C) Le droit de modifier les données des autres

6. Dans un projet, à quoi sert principalement le registre des traitements ?

A) À décrire et piloter les traitements : finalité, données, durées, sécurité

B) À remplacer les mesures de sécurité

C) À facturer les clients

7. Une licence logicielle confère en principe à l'utilisateur…

A) La propriété du logiciel

B) Le droit de revendre le code source

C) Un droit d'usage encadré par des conditions

8. Un hébergeur qui stocke les annonces d'utilisateurs engage sa responsabilité surtout si…

A) Un contenu est simplement impopulaire

B) Il laisse en ligne un contenu manifestement illicite valablement signalé

C) Il héberge beaucoup de contenus

9. Se connecter au système d'une entreprise sans autorisation, « juste pour tester », constitue…

A) Une infraction potentielle d'accès frauduleux

B) Un service rendu à l'entreprise

C) Un droit pour tout informaticien

10. Une image de signature scannée et collée dans un PDF…

A) Vaut toujours signature qualifiée

B) Interdit tout litige

C) Ne garantit ni l'identité ni l'intégrité du document

Corrigés du QCM

1. Réponse A — La loi n° 2013-015 du 21 mai 2013 est le texte malien de référence ; l'APDP veille à son application. Le RGPD est une référence internationale qui ne remplace pas la loi malienne.

2. Réponse B — Une donnée personnelle identifie une personne physique, directement ou indirectement : le numéro de téléphone d'un client en est un exemple typique.

3. Réponse C — Minimisation = adéquation et limitation : chaque donnée collectée doit être justifiée par l'objectif du traitement.

4. Réponse B — Le responsable du traitement décide du « pourquoi » et du « comment » ; le sous-traitant agit pour son compte avec des garanties de sécurité.

5. Réponse C — Les droits reconnus (information, accès, rectification, opposition, effacement selon les cas) portent sur ses propres données, jamais sur celles d'autrui.

6. Réponse A — Le registre est l'outil de pilotage et de preuve de la conformité : il recense chaque traitement et ses caractéristiques.

7. Réponse C — Acheter un logiciel, c'est obtenir un droit d'usage selon les conditions de la licence, propriétaire ou libre.

8. Réponse B — Le régime de l'hébergeur : pas de surveillance générale, mais une action prompte obligatoire après signalement d'un contenu manifestement illicite.

9. Réponse A — L'accès et le maintien frauduleux sont des infractions dans les législations sur la cybercriminalité ; seul un mandat écrit du propriétaire rend le test légal.

10. Réponse C — Une image peut être copiée et le document modifié sans trace ; la signature électronique juridique repose sur un procédé d'identification lié au document.

Résumé — les notions importantes

• Cadres : au Mali, la loi n° 2013-015 du 21 mai 2013 protège les données personnelles sous le contrôle de l'APDP ; la Convention de Malabo harmonise les principes en Afrique et le RGPD européen sert de référence mondiale — mais les textes évoluent, on vérifie la version en vigueur.

• Une donnée personnelle identifie une personne directement ou indirectement ; tout traitement doit poursuivre une finalité déterminée, collecter le minimum, garantir l'exactitude, limiter la conservation et assurer la sécurité.

• Responsable du traitement et sous-traitant ont des rôles distincts ; les personnes disposent de droits (information, accès, rectification, opposition, effacement selon les cas) qui doivent pouvoir s'exercer concrètement.

• Le registre des traitements est l'outil central de conformité : il décrit chaque traitement et prouve la diligence de l'organisation.

• Les contrats informatiques sécurisent les projets : périmètre, recette, propriété intellectuelle, responsabilité, niveaux de service ; une licence logicielle donne un droit d'usage conditionné, pas la propriété du programme.

• Éditeur et hébergeur n'ont pas la même responsabilité : l'hébergeur, sans devoir de surveillance générale, doit retirer promptement tout contenu manifestement illicite qui lui est signalé.

• Cybercriminalité : l'absence d'autorisation fait l'infraction pour les atteintes aux systèmes ; la signature électronique et des traces fiables et licites fondent la valeur de la preuve numérique.

Vidéos associées aux leçons

Ces vidéos, en français, complètent les leçons. Liens vérifiés au moment de la publication de ce document.

Leçon 2 — Les bases du RGPD en 5 minutes !

Chaîne : AKE'hA · Langue : Français · Niveau : Débutant

Une introduction claire et rapide au RGPD : ce qu'est une donnée personnelle, les grands principes et les droits des personnes. Parfait pour fixer le vocabulaire avant d'appliquer les mêmes principes au cadre malien de la loi de 2013.

https://www.youtube.com/watch?v=HaBVdJbGyP8

Leçon 2 — RGPD : Qu'est-ce qu'une donnée personnelle ?

Chaîne : Leto · Langue : Français · Niveau : Débutant
La vidéo démonte la notion centrale du cours : informations directes et indirectes, pseudonymisation et anonymisation, et pourquoi une adresse IP peut être une donnée personnelle. À regarder en refaisant mentalement l'exercice du formulaire de livraison de la leçon 2.

https://www.youtube.com/watch?v=muSdwpDrYEY

Leçon 2 — 5- Le registre des traitements - RGPD - Protection des données

Chaîne : DPO Manager · Langue : Français · Niveau : Intermédiaire
Le registre des traitements expliqué pas à pas : finalités, bases légales, durées de conservation, sécurité et validation. Le TD de ce cours te demande exactement ce travail pour une clinique : la vidéo montre sa forme concrète dans un outil dédié.

https://www.youtube.com/watch?v=rDExHz_5yBM

Leçon 5 — Qu’est ce que la cybercriminalité

Chaîne : Expert Informatique · Langue : Français · Niveau : Débutant
Une présentation des principales formes de cybercriminalité rencontrées par les enquêteurs : intrusions, escroqueries en ligne, atteintes aux systèmes et usurpations d'identité. Elle illustre les familles d'infractions de la leçon 5 du point de vue de l'investigation.

https://www.youtube.com/watch?v=APHQNI1aRJQ

Leçon 6 — La preuve numérique au travail (adresse IP, signature électronique...)

Chaîne : HAAS Avocats - Droit IT-IP · Langue : Français · Niveau : Intermédiaire
Des avocats spécialisés discutent de la valeur des preuves numériques : adresse IP comme donnée personnelle, recevabilité des enregistrements et différence entre signature simple et qualifiée. Un prolongement direct de la leçon 6 pour comprendre comment les juges raisonnent.

https://www.youtube.com/watch?v=XYF92p0PQAo

Sources et références

- Loi n° 2013-015 du 21 mai 2013 relative à la protection des données à caractère personnel (Mali) et Autorité de Protection des Données à caractère Personnel (APDP) — consulter le site et les publications de l'APDP pour la version en vigueur et les formalités déclaratives.
- Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel (Convention de Malabo, adoptée en 2014, entrée en vigueur en 2023) — texte disponible auprès de l'Union africaine.
- Règlement (UE) 2016/679 (RGPD), applicable depuis le 25 mai 2018 — référence internationale en matière de protection des données ; voir aussi les ressources pédagogiques des autorités européennes de protection des données (par exemple la CNIL, France).

• Loi française n° 2004-575 du 21 juin 2004 pour la confiance dans l'économie numérique (LCEN) — référence fréquemment citée dans l'espace francophone pour la responsabilité des hébergeurs et des éditeurs ; règlement (UE) n° 910/2014 (eIDAS) pour la signature électronique.

• Programme officiel Licence Informatique, Université IAM (Institut Africain de Management), Bamako — et, pour tout cas réel, le conseil d'un avocat ou d'un juriste d'entreprise : ce cours donne des repères, pas des consultations.

Fin du cours — Bronbah Tech, Bibliothèque Universitaire IAM. Bon courage pour tes révisions !